AUTHORIZED SECURITY LAB DOSSIER

Legal Scope, Asset Inventory & Threat Model

Prepared by: Student / Security Analyst (PUSHPARAJ B)

Lab owner: RabTech lab (as identified in starter inventory)

Prepared on: 09 November 2026

Environment: Isolated training lab

Document status: Planning dossier — authorization and implementation evidence pending

CONFIDENTIAL — TRAINING PURPOSES ONLY

1. Executive Summary

This dossier defines a bounded, non-destructive security engagement for two training assets listed in the supplied starter inventory. It documents authorization conditions, asset scope, a conceptual data-flow view, STRIDE abuse cases, risk-based mitigations, and rules of engagement.

Current status: planning and documentation. Written owner approval, approved testing dates, actual lab implementation, and technical validation evidence have not been supplied. No vulnerabilities are claimed as confirmed.

2. Authorization and Scope

The engagement is limited to LAB-01 (http://127.0.0.1:8080) and LAB-02 (192.168.56.20 on a private host-only network), as listed in the starter inventory. Testing may begin only after the lab owner confirms in writing the assessor, assets, permitted activities, test window, rate limits, and emergency contact.

Out of scope: public websites, third-party systems, personal devices, unlisted IP addresses, denial of service, destructive actions, persistence, malware, credential theft or reuse, uncontrolled data extraction, and outbound traffic from the isolated VM.

3. Written Authorization Record

Lab owner: RabTech lab (approval pending). Assessor: Student / Security Analyst (name to be entered). Approval date, testing window, emergency contact, and owner signature must be completed by the authorized owner. This document is not itself an owner signature or proof of authorization.

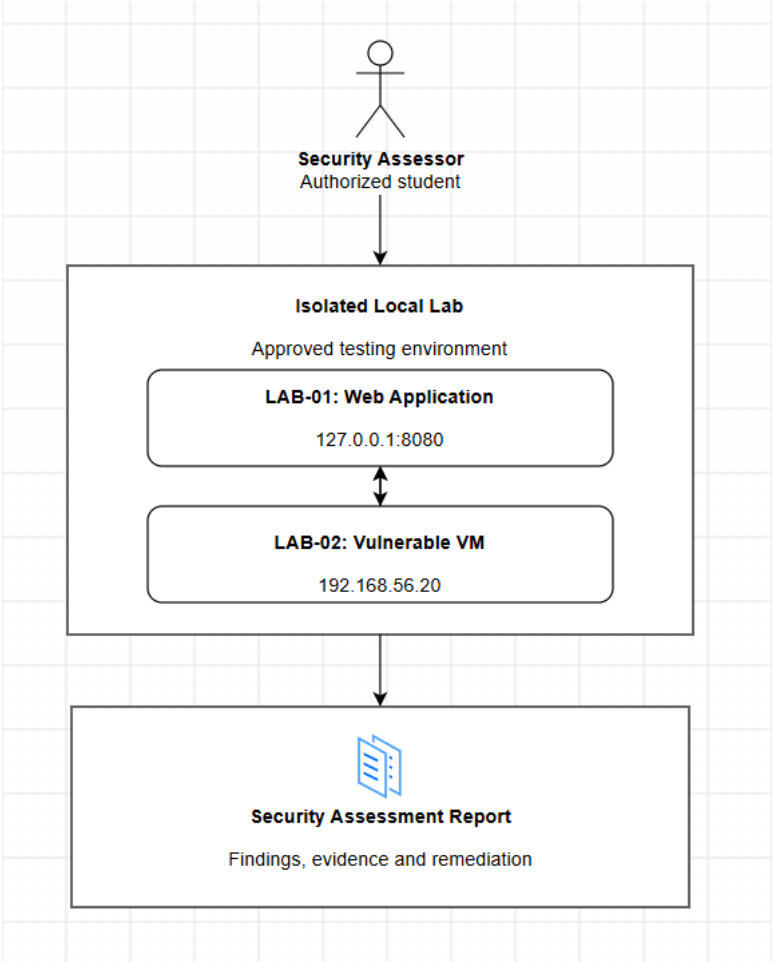
If the supplied LAB-01 application is unavailable, OWASP Juice Shop may be proposed as a local substitute only with instructor/lab-owner approval. It must not be represented as the supplied RabTech application. LAB-02 must not be marked configured until the actual VM image is received and its host-only address verified.

4. Asset Inventory

ID	Asset	Environment	IP / URL	Testing	Attack surface	Potential risk

LAB-01	Local training web app	Isolated localhost	http://127.0.0.1:8080	Yes - only after written authorization	HTTP endpoints, login forms, input fields	Potential SQL injection, XSS, authentication weaknesses; not confirmed
LAB-02	Deliberately vulnerable VM	Private host-only network	192.168.56.20	Yes - only after written authorization	Network services, open ports, OS services	Potential misconfiguration, weak authentication, outdated services; not confirmed

5. Lab Architecture and Data Flow



The diagram is conceptual. It shows the assessor interacting only with the approved isolated lab boundary and a report being produced. It does not assert that LAB-01 and LAB-02 communicate directly. Verify actual connectivity before documenting any connection.

6. STRIDE Threat Model

STRIDE categories: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege. The following are illustrative abuse cases, not confirmed vulnerabilities.

ID / Category	Affected asset	Threat scenario	Score / Priority	Mitigation
TH-01 / Spoofing	LAB-01 / LAB-02	An unauthorized person may impersonate a legitimate user or service identity.	16 / Critical	Use unique test accounts, strong authentication, MFA where supported, and secure session handling.
TH-02 / Tampering	LAB-01	An attacker may alter application input or stored records without authorization.	12 / High	Validate input server-side; enforce authorization on every change; use parameterized queries and integrity checks.
TH-03 / Repudiation	LAB-01 / LAB-02	A user may deny an action if security-relevant events are not logged.	9 / Medium	Record timestamped security events with actor and outcome; protect logs from alteration; avoid

				logging secrets.
TH-04 / Information Disclosure	LAB-01 / LAB-02	Sensitive training data, configuration, or credentials may be exposed.	15 / High	Minimize data, enforce least privilege, encrypt sensitive data, redact logs, and restrict evidence access.
TH-05 / Denial of Service	LAB-01 / LAB-02	Excessive requests or resource exhaustion may disrupt service.	10 / Medium	Use rate limiting, resource monitoring, safe request limits, and operational alerts. Do not perform DoS tests.
TH-06 / Elevation of Privilege	LAB-01 / LAB-02	A low-privilege account may gain permissions beyond its intended role.	15 / High	Apply server-side role-based access control, least privilege, and authorization checks on sensitive actions.

Risk score = Likelihood × Impact. Preliminary scoring guide: 1–5 Low; 6–10 Medium; 11–15 High; 16–25 Critical. Reassess scores against the actual architecture, exposure, and business impact.

7. Rules of Engagement

- Authorization: written owner approval is required before testing.
- Permitted after approval: non-destructive asset/service identification, review of authentication and authorization using test accounts, input validation review with safe test data, configuration review, and reporting.
- Excluded: denial of service, destructive payloads, malware, persistence, credential theft/reuse, third-party scanning, unlisted targets, uncontrolled data extraction, and outbound VM traffic.

- Testing window: start/end times and time zone to be approved by the owner. No testing outside the approved window.
- Stop conditions: unexpected outage or instability; target mismatch; external traffic; exposure of real personal data or secrets; risk of data loss; or withdrawal of authorization.
- Evidence: collect minimum necessary evidence, use synthetic data, redact secrets and personal information, restrict storage, and agree a retention/deletion date.
- Reporting: document finding ID, asset, description, severity rationale, impact, safe reproduction steps, evidence, remediation, and validation status.

8. Implementation Evidence

Attach genuine screenshots after implementation. Suggested evidence: Docker engine running; local training application visible; container status with loopback-only port mapping; host-only VM network settings if LAB-02 is supplied; and redacted owner approval. The evidence checklist is provided separately.

9. Conclusion

The dossier establishes a defined proposed boundary and a structured threat-modeling approach. It is ready for owner review, but the engagement remains in planning status until written authorization, testing dates, and real implementation evidence are completed.